

Decision Rationale: How the Harborline Policy Was Built

This document explains the reasoning behind the Harborline Cyber Protection Policy: who it is for, how its numbers were set, what it covers and leaves out, and the trade-offs I accepted. It follows the order in which I made the decisions. Each step answers one question, and each answer sets part of the policy.

A note on numbers. Harborline and Cedar Ridge are fictional. Market statistics come from the published sources listed at the end. At-Bay figures come from the full 2026 InsurSec Report; most others were checked against the publishers' own summaries. Premiums, limits and loss estimates for Cedar Ridge are my own illustrative judgments, and the arithmetic is shown so each can be challenged.

Summary

What the policy is for. Harborline keeps a small business open and solvent after a cyber event. It pays the losses the business can't absorb, pays them fast enough to keep it running, and leaves the small, predictable costs with the business. Every term had to serve that purpose, or protect the insurer's ability to keep offering it (by limiting moral hazard, accumulation or what the law forbids).

Who it's for. U.S. businesses with \$1M–\$50M in revenue, such as accounting firms, clinics, agencies, retailers and light manufacturers. In my view, most buy cyber insurance to survive ransomware and fraud, and many have no broker or in-house IT team to guide them. The sample policyholder is Cedar Ridge Accounting Group, a Denver CPA firm with \$8.5M revenue and 62 staff that runs payroll for 40 clients.

The five decisions that matter most:

1. **The losses that hit small businesses most are always covered.** Breach response, ransomware, downtime and payment fraud are in the core. Rarer or systemic risks are priced options.
2. **Numbers come from how these businesses lose money.** The retention is set at what a business can absorb; the limit at the worst realistic single event. For Cedar Ridge that means a \$2M limit, not the \$1M I started with.
3. **Payment fraud is written around how firms that move money actually get robbed.** It covers partners, the bank and client accounts, because U.S. courts have repeatedly denied these losses under narrower wording.
4. **Security affects price, not whether you're covered.** Only three disclosed terms can reduce a payment for security reasons, and each applies only if the gap mattered to the loss.
5. **Cash timing is treated as a coverage issue.** Seven days of free first response, a firm 50% business interruption advance within 10 business days, and payment standards backed by interest.

What I deliberately left out, with reasons in part 9: unlimited reinstatements and per-event limits, parametric downtime payments, full-limit system failure in the core, and fault-based payment reductions borrowed from German law.

1. Who the policy is for, and why

Question	Answer	Reason
Segment	U.S. businesses with \$1M–\$50M revenue	The brief asks for a small-to-mid-sized business. In my judgment this is also where standalone cyber cover is thinnest: many firms rely on a small cyber sublimit inside a business owners policy, as Cedar Ridge did (\$50,000)
Paper	Admitted, Colorado law	Small businesses buy directly or through generalist agents and expect a filed, state-regulated form. Admitted paper is now common (Beazley, Cowbell, and since August 2026 Corgi's own admitted carrier), so it is a baseline rather than a selling point
Form design	One general form; Declarations show what each business bought	The same wording works for a dental office or a CPA firm. The Declarations, the options and the application carry the differences
Sample policyholder	Cedar Ridge Accounting Group	A demanding test: it holds Social Security numbers for thousands of people, moves client money, depends on cloud tax and payroll platforms, and peaks in tax season

Fit with Corgi. Corgi Insurance Company, Inc., Corgi's admitted carrier announced on August 26, 2026, targets main-street businesses including professional and administrative offices. Harborline is written as the kind of cyber form such a carrier could file for that segment, and for startups graduating into it. Corgi's own startup cyber policy is sold at up to \$1M per claim and \$2M aggregate. I kept that two-number way of thinking about limits, but sized the numbers from small-business losses rather than startup contract requirements (part 3).

2. How these businesses lose money

Every coverage in the policy maps to a row in this table, and every row has a coverage or a stated reason why not.

#	How the money is lost	How often and how much	What it means for a firm like Cedar Ridge	Coverage
L1	Payment fraud: fake invoices, spoofed partner or client emails, bank impersonation, altered payroll batches	The most common claim type. Business email compromise and funds transfer fraud made up 58% of Coalition's 2025 claims. At-Bay's average fraud loss was \$208K for firms under \$25M revenue (\$285K across all sizes)	Cedar Ridge moves about \$2.4M a month of client payroll. One diverted batch (up to about \$210K) is a loss it would have to make good	H (and R)
L2	Ransomware: downtime, restoration, extortion	Less frequent, but the most severe: At-Bay's average ransomware claim was \$422K for firms under \$25M (\$508K across all sizes)	Cedar Ridge can run about one day without its systems in tax season. Revenue averages about \$34K per business day, more in February to April	C, D, F, A, B
L3	Data breach: notification, credit monitoring, then lawsuits and regulators	Data-breach class actions reached a record 1,822 filings in 2025. Separately, Coalition reported that privacy-rights claims, mostly website-tracking suits, doubled in the first half of 2026	About 31,000 people's records, most with Social Security numbers. Tax data breaches also trigger identity-theft follow-up with the IRS	B, I, J, K (Q for tracking suits)

#	How the money is lost	How often and how much	What it means for a firm like Cedar Ridge	Coverage
L4	Vendor or cloud outage	Vendors and customers caused 14% of At-Bay's 2025 claims, averaging \$145K. In my judgment, multi-day outages of shared platforms are uncommon but severe	The outages CPA firms remember were attacks: CCH (May 2019, malware, days, with an IRS filing extension) and Kronos (December 2021, ransomware, weeks). A platform's own bad update or internal failure is the non-malicious version	E (attacks on vendors); P (non-malicious, optional)
L5	Own system failure: a bad update or failed server	CrowdStrike (July 2024) showed one faulty update can hit many firms at once	Usually small for a firm with tested backups	D and F, capped
L6	Regulators	Follows L3	Tax preparers are covered by the FTC Safeguards Rule and must report breaches of unencrypted data affecting 500 or more people within 30 days	J
L7	Rogue insider	Rare	An IT lead with admin rights	Built into security failure
L8	AI-enabled attacks: cloned voices, deepfake video calls, hijacked AI agents	Rising. Coalition said in December 2025 that deepfakes were still a small fraction of claims; so far mostly a new route to L1 and L2	Partner voice cloning to push an urgent payment in tax season	Through L1 and L2; AI-agent definitions

3. The structure: retention, limit and sublimits

The retention: what the business can absorb

Revenue band	Standard retention	About how much of a day's revenue
Under \$2.5M	\$2,500	A quarter to a whole day
\$2.5M–\$5M	\$5,000	A quarter to half a day
\$5M–\$25M	\$10,000	A tenth to half a day
\$25M–\$50M	\$25,000	A tenth to a quarter of a day

The retention does three jobs:

1. **It stays absorbable.** For Cedar Ridge, \$7,500 after its security credit is under a quarter of one day's revenue, and about 0.09% of annual revenue.
2. **It filters out small claims.** Small claims cost more to handle than they pay. Coverage A handles minor events at no cost, so the retention bites only on real incidents.
3. **It rewards the controls that stop losses.** MFA plus EDR cuts it by 25%. A 24/7 managed detection and response service cuts it by 50%. Credits don't stack; the insured gets the single best one.

The claim-free reduction (25% a year, to a floor of \$2,500) is a loyalty and security incentive. It is conditional on fixing critical issues we report, so it is kept modest.

The limit: what would sink the business

A limit should cover the worst realistic single event, then be checked for price. For Cedar Ridge that event is a tax-season ransomware attack with data theft:

Cost	Estimate
Forensics, breach coach, negotiation	\$100K–\$150K
Restoring systems and data	\$100K–\$200K
Lost income (about 10 business days in season, after the 8-hour wait)	\$250K–\$450K
Notification and credit monitoring	\$100K–\$250K
Regulator defense	\$25K–\$100K
Subtotal without a lawsuit	about \$0.6M–\$1.2M
Class action (I assume a 25–35% chance after a Social Security number breach)	+\$0.3M–\$1M
Severe total	about \$0.9M–\$2.2M

A \$1M limit covers the typical claim easily. At-Bay's average claim was \$180K for firms under \$25M revenue (\$221K across all sizes), and Coalition's average across all its policyholders was \$116K. But a \$1M limit can run out in exactly the event that would threaten the business. A \$2M limit covers it.

I also considered Corgi's structure of \$1M per claim with a \$2M aggregate. That protects against two bad events in one year. It does not protect against one very bad event, which is the real danger for a small business. By my estimate, raising the single-event cover to \$2M is worth \$60–150 a year in expected payments to Cedar Ridge. A second, separate \$1M is worth under \$5.

The limit rule (shown on the application's underwriter page): - **\$1M** is the base. - **\$2M** for businesses holding more than about 25,000 sensitive records, moving client money, or depending on a seasonal peak. - **\$3M** where a contract requires it.

I capped this form at \$3M. Above that, businesses in this band usually need a tailored program with excess layers, which a simple rating plan shouldn't try to price.

Sublimits: where the insurer needs a narrower cap, and why

Sublimit	Amount	Reason
System failure (D and F combined)	\$250K, "applies across coverages"	Accumulation: one bad vendor update can hit many insureds at once (CrowdStrike, 2024). The label matters: in <i>CiCi Enterprises v. HSB Specialty</i> (N.D. Tex., February 2026), a court refused to apply a ransomware sublimit across coverages because the wording didn't say it did. A full-limit option is available and priced
Payment fraud (H)	\$250K core; \$500K or \$1M option (R)	Covers At-Bay's \$208K average fraud loss. Firms that move client money need more: Cedar Ridge's largest batch is about \$210K, so it buys \$500K
Fraud without a verification procedure	\$100K	Moral hazard: callback verification stops most payment fraud. It applies only if the business had no procedure or training, never when the bank was deceived, and one person's slip never triggers it
Dependent business interruption (E)	\$500K	Accumulation across shared vendors, balanced against the 14% of claims that vendors or customers caused

Sublimit	Amount	Reason
Dependent system failure (P, optional)	\$250K, 24-hour wait	The most systemic trigger, so it is optional, with a longer wait. It covers a platform's own bad update or internal failure lasting more than a day (the non-malicious counterpart of the CCH and Kronos attacks, which Coverage E covers), not short blips
Coverage A	\$25K per incident, \$75K per year, outside the aggregate	Encourages early calls, which make losses smaller; capped so it can be priced
Bricking, reputational harm, cryptojacking	\$100K, \$100K, \$50K	Real but smaller exposures, included in the core as leading forms now do

4. What the policy covers, and why

The coverages follow Coalition's plain "we will pay" style and At-Bay's split between first-party and liability triggers. They are lettered to match the Declarations.

Coverage	Loss path	Borrowed from, and what I changed	Why
A. Incident response, 7 days, outside the limit, no retention	All	The Coalition policy issued for 2025–26 (72 hours of breach response outside the limit); extended to 7 days	Email-compromise reviews often run past 72 hours. The dollar cap is unchanged, so the extra time costs little but finishes small cases without a retention
B. Breach response, including suspected events	L3	At-Bay's event definitions	Businesses shouldn't wait for proof before calling. B also pays to help people with tax-related identity theft, a real follow-on cost when tax data is stolen
C. Extortion, with "paying is never required"	L2	Coalition's consent rules; the OFAC 2021 advisory; the UK National Cyber Security Centre's 2024 guidance with the insurance associations	Without the "never required" line, a "reasonable steps to resume operations" condition could be read to push an insured to pay
D. Business interruption: attacks at full limit, system failure capped	L2, L5	The market's post-CrowdStrike distinction between malicious and non-malicious triggers (see Aon, July 2024)	Each trigger carries different accumulation risk
E. Dependent business interruption (attacks on vendors)	L4	At-Bay's external computer systems; Coalition's hosted systems	Vendors and customers caused 14% of At-Bay's 2025 claims
F. Data restoration	L2, L5	Coalition; At-Bay; Beazley BBR 5.0 added system failure	Restoration is a large part of ransomware cost
G. Security improvement costs	L2	At-Bay's post-event hardening; Coalition's betterment allowance	A small, clear budget to fix the weakness that was exploited
H. Payment fraud and invoice fraud	L1	HSB Cyber Suite's single "wrongful transfer event" trigger (deception of the insured or its bank); CFC's client-account cover; Coalition's invoice manipulation	See below

Coverage	Loss path	Borrowed from, and what I changed	Why
I. Privacy liability, including employees' own claims	L3	Coalition carves back employee claims; Corgi sells this by endorsement	Payroll and HR data breaches are common
J. Regulatory defense and penalties, including agencies outside the U.S.	L6	At-Bay and Coalition (core)	Breach notice deadlines of 30–60 days make regulatory scrutiny normal
K, L. PCI and media	L3	At-Bay, Coalition, Cowbell Prime 100 (core)	Most small businesses take cards and publish content
M, N, O. Bricking, reputational harm, cryptojacking (now including AI-service charges)	L2, L3	Similar cover appears in the base forms of Coalition's Active Cyber Policy and Beazley BBR 5.0	Real exposures; small sublimits keep them affordable
P–T and the system-failure option	L4, L5, others	Optional	Systemic, rare or class-specific risks stay priced and visible

Why payment fraud was rewritten. Fraud coverage is where U.S. courts disagree most often. Three examples: - In *Taylor & Lieberman v. Federal Insurance* (9th Cir. 2017), an accounting firm that wired a client's money after a spoofed email was denied coverage. - In *RealPage v. National Union* (5th Cir. 2021), the insured controlled client funds but did not "hold" them. - In *Mississippi Silicon v. AXIS* (5th Cir. 2021), an employee-authorized transfer fell to a small social-engineering sublimit.

In *Apache v. Great American* (5th Cir. 2016), a spoofed email was held "merely incidental" to an authorized transfer, so the loss did not result "directly" from computer use. My first draft had four of these gaps: - only employees could be deceived, not partners; - only the insured, not its bank; - only accounts the insured "held" for clients; - a "direct result" test.

The new **payment fraud** definition closes all four. It covers anyone authorized to make, approve or change payments, including partners and AI agents. It covers the insured or its **financial institution** being deceived, and client accounts the firm operates. It uses "resulting from". It also tells the insured to preserve its rights against the bank, since a bank must sometimes refund a fraudulent transfer.

5. What the policy limits or excludes, and why

Every restriction names one of five reasons: - **MH**: moral hazard; - **ACC**: accumulation; - **PP**: public policy or law; - **OP**: another policy covers it; - **NP**: can't yet be priced.

Restriction	Reason	It applies only when
20% ransomware coinsurance without verified backups	MH	Backups weren't verified, the loss is restoration or downtime from encryption, and the gap mattered. It never applies if the insured restores from its own backups anyway
20% coinsurance for a known-exploited vulnerability	MH	We warned the insured's contacts in writing, it stayed unpatched and unmitigated for 45 days, and an attacker used it. It never stacks with the ransomware coinsurance
\$100K fraud limit	MH	No verification procedure or training existed, and that mattered to the loss

Restriction	Reason	It applies only when
System failure cap; infrastructure exclusion; war exclusion	ACC	The event is a systemic one (a vendor update, a utility or internet backbone failure, or a state-backed operation)
Intentional wrongdoing	MH	A final ruling or admission establishes it. It applies to the firm only if its top leaders took part or knew
Known problems	MH	An executive knew before the continuity date and should have expected a loss. Unexploited weaknesses and anything disclosed are carved out
Sanctions; uninsurable penalties and punitive damages	PP	The law forbids payment. Colorado does not allow punitive damages to be insured, and the policy says so plainly
Bodily injury, property damage, patents, employment practices, securities	OP	Another line of insurance is built for it. Breach-related emotional distress and employee privacy claims stay covered
Wrongful collection (tracking pixels) and biometric collection laws	NP	The claim is about how data was collected, not a breach. Coverage Q offers pixel cover for businesses that need it

One rule for security. Section III, part 1.9 lists the only three terms that can reduce a payment because of security practices, and applies each only if the missing control caused the incident or made the loss larger. The insurer must show that link. The idea comes from the UK Insurance Act 2015 (s11), which stops an insurer relying on a risk-control term when the breach could not have mattered to the loss. I found no Colorado equivalent, so the policy supplies the rule itself.

I did not copy the German approach of cutting payment in proportion to how careless the insured was. In a Colorado form that becomes a discretionary percentage dispute, and it can't be priced.

The war exclusion. At-Bay's AB-CYB-001.2 (08/2023) form and the Coalition policy issued for 2025–26 that I reviewed still use legacy "war, hostilities, warlike operations" wording. That is the kind of language the New Jersey courts refused to apply to NotPetya in *Merck v. ACE*. Harborline follows the Lloyd's Y5381 criteria and the LMA 5567 model clause, and borrows the physical-force war definition and bystander carve-back from Beazley's war and cyber war exclusion. Beazley's clause has no attribution process, so Harborline uses LMA 5567's rule (attribution by the government where the affected systems are located). It adds what the models lack for small insureds: - continued help while attribution is pending, with no repayment; - a plain statement that the insurer bears the burden of proof; - a reminder that "state" means a sovereign country, never a U.S. state, which matters in a U.S. form.

6. How the definitions are built

Principles: 1. Each definition is a plain "means" statement, in alphabetical order. 2. Each concept has one definition, used everywhere. 3. Definitions are broad where small businesses get hurt (rogue insiders, personal devices, paper records, deepfakes by any channel) and tight where risk accumulates (utilities, public internet infrastructure).

Definition	Choice	Why
Cloud accounts and computer systems	The accounts, tenants and data an insured controls in an online service are its own computer systems . The provider's own servers are dependent systems	My first draft let a Microsoft 365 mailbox be read as both. That ambiguity cuts both ways on the most common claims. An added tie-breaker sends a vendor-side attack that reaches your account to your own coverages, and the vendor's outage to Coverage E or P

Definition	Choice	Why
Payment fraud, financial institution, client accounts	One trigger for every way a firm is tricked into moving money	Part 4 above
Discover	When an executive or the named security contact becomes aware of facts suggesting an incident	Triggers, notice and exclusions all turn on this word; it was undefined
Early warning	A notice from the FBI, a bank, the IT provider or us is always a suspected incident, but not by itself "discovery"	Small firms usually learn of an attack from outsiders. They shouldn't have to argue about whether an FBI call was "reasonable suspicion", and an alert that finds nothing shouldn't count against them
Related	A common cause, the same attacker's continuing access, or a causally connected series	One incident means one limit and one retention. Reports made during the policy lock in later claims
Executive	Named leaders and the designated IT or security lead, not an outside IT provider	Knowledge and exclusions should turn on the people who would actually know
Security failure and system failure	A hijacked AI agent is a security failure. An AI agent that simply malfunctions is a system failure	Matches how the risk behaves, and routes each to the right limit
Public internet infrastructure	The public DNS root and top-level-domain servers, internet exchange points and backbone networks, not a provider's own systems	The October 2025 AWS outage reportedly began with a DNS fault inside AWS. Loose "internet infrastructure" wording could have excluded exactly that kind of vendor outage
Damages	Contract duties to protect data or pay for notices stay covered; punitive damages are included only where insurable	Client contracts routinely require data protection

7. Underwriting and price

The application explains the price. Security questions follow the six functions of NIST CSF 2.0 and the CIS Controls v8.1 safeguards. Every starred answer maps to a credit or term on the underwriter page. I added questions underwriters now ask: - systems past end of support; - how the IT provider connects; - whether backups are protected from the firm's own admins; - IRS e-file credential protection; - client payroll volumes; - professional liability in force.

I also removed traps. The application no longer asks the insured to state legal conclusions (for example, whether it falls under a privacy statute); it asks for facts. Optional answers can't be used against the insured.

Monitoring and services. Insurtech carriers such as Coalition and At-Bay use scans and alerts both to choose risks and to prevent losses. Harborline scans before issue and warns about known-exploited vulnerabilities. Other services sit outside the contract. Colorado's 2025 rebate reform (SB25-058) allows value-added loss-mitigation services not specified in the policy. The policy promises that using them, or not, never reduces cover.

Premium for Cedar Ridge (illustrative):

Line	Amount
Core coverages at the \$1M base limit (about 0.07% of revenue for a professional-services risk)	\$6,120

Line	Amount
Increase to \$2M (25% of base, because most claims never reach \$1M and sublimits don't grow)	\$1,530
Coverage P, \$250K with a 24-hour wait	\$600
Coverage R, fraud limit to \$500K	\$280
10% credit for hardened remote access	-\$853
Total	\$7,677

Does it hold up against expected losses?

Expected annual loss	Low	Mid	High
Claim frequency (Coalition: 1.21% for businesses under \$25M revenue; I assume higher for firms holding tax data)	1.2%	1.5%	1.8%
Average paid claim after retention	\$110K	\$150K	\$175K
Claims within the first \$1M	\$1,320	\$2,250	\$3,150
Coverage A and pre-incident help	\$250	\$400	\$600
The second \$1M	\$60	\$100	\$150
Coverage P	\$250	\$450	\$700
Coverage R	\$20	\$45	\$80
Total expected loss	\$1,900	\$3,245	\$4,680
Expected loss ratio at \$7,677	25%	42%	61%

The mid case leaves room for claims handling, services, acquisition costs, a load for tax-season accumulation on Coverage P, and profit. The high case would call for a rate review. The 2026 market is soft (Marsh reported U.S. cyber rates down 2% in Q2 2026), so I did not price for rate increases. An actuary should replace this sketch with filed rates.

At \$1M with no options, the same business would pay \$5,508. The rationale for spending the extra \$2,169 is part 3's severe-event table.

8. How claims are paid

Promise	Why
24/7 hotline; we aim to call back within one hour	Early response shrinks losses
We pay vendors directly	Small businesses can't front forensic and legal fees mid-crisis
A 50% business interruption advance within 10 business days, up to 25% of the aggregate	Coalition's 2026 cash-advance feature is discretionary. Payroll doesn't wait for forensic accountants, so ours is firm
One forensic accountant, if the insured chooses	Two competing accountants can take months to agree
A written coverage position we aim to give within 30 days; payment within 15 days of agreement, or 8% interest compounded annually (Colorado's statutory rate) on top of any legal remedy	Only the payment promise carries a contractual remedy. The others are stated as aims, and Colorado's unfair claims practices law still applies

Promise	Why
Free internal review, then insurer-paid mediation	A path to challenge decisions without hiring lawyers first
Late notice of incidents reduces payment only if it caused harm; claims have a firm 90-day window after expiry	Colorado enforces claims-made reporting deadlines strictly (<i>Craft v. Philadelphia Indemnity</i> , 2015), so the policy says the claims deadline is firm and makes the automatic 60-day extended reporting period cover claims first made during it
Honest application mistakes change only price, retention and credits	In <i>Travelers v. International Control Services</i> (C.D. Ill. 2022), after Travelers alleged a false MFA answer, the insured agreed to an order rescinding its policy from inception. There was no ruling on the merits, but the case shows the risk
Cancellation only for non-payment (10 days, with reasons), a knowingly false application answer (45 days), or an honest application error that shows a substantially different risk we would not have written (60 days)	Colorado (C.R.S. 10-4-109.7) allows cancellation of a commercial policy only for non-payment, a knowingly false application statement or a substantial change in the risk from what the application described, and requires 45 days' notice for all but non-payment
Coverage I responds even where the firm's professional liability policy might also apply	Stops a client lawsuit after a breach falling between two policies

9. Trade-offs, and what I'd test next

Considered	Decision	Why
Per-event limits (Brit C360, March 2026) or unlimited reinstatements (CFC)	Declined	Uncapped frequency is hard to rate and reinsure on admitted paper. For a small business, one severe event is the bigger risk, so a higher single limit protects more per dollar
Parametric "fast downtime payment" (AIG with Parametrix, August 2026; a UK Lloyd's Market Association draft)	Declined for now; test next	For a CPA firm it would pay for downtime that is mostly deferrable, at 25–50% of the premium. Every firm on the same platform would claim at once. The firm 50% advance delivers cash speed for attacks
Full-limit system failure in the core (Coalition's surplus-lines form)	Priced option	Accumulation. Harborline is narrower than Coalition here, and says so
Deepfake and impersonation response (Coalition, December 2025)	Optional Coverage T	Real, but a small-dollar exposure. Deepfake-driven payment fraud is already covered in H
\$0 retention paths (At-Bay's MDR packages; Coalition's in-house incident response)	Credit only	Harborline doesn't sell MDR or run its own response team; the 50% credit rewards MDR
AI regulatory defense (Beazley, September 2026)	Later	Colorado's AI law takes effect in 2027. Penalties under it are likely uninsurable
German fault-based payment cuts (VVG §28)	Declined	Not priceable, and a source of disputes under Colorado bad-faith law. Part 1.9's causation rule takes the fair part

Where Harborline is broader than the forms I compared: - any-channel fraud, including bank and client accounts; - employee privacy claims; - paper records; - rogue insiders; - forensic accounting; - the firm cash advance; - "paying a ransom is never required".

Where it is narrower: - the \$250K system-failure cap; - optional vendor system failure; - 70% rather than 80% on the settlement clause (At-Bay's AB-CYB-001.2 form uses 80%).

With more time I would: - price every term against claims data with an actuary; - confirm state rules with counsel before filing outside Colorado; - review the war wording with reinsurers; - test the Declarations with five small-business owners; - measure the claims service standards against real results.

10. How I validated this

I checked the draft three ways: 1. **Consistency.** Every bold term is defined, and the Declarations match the wording. 2. **Law.** A Colorado and U.S. legal review of each clause, covering notice, cancellation, punitive damages, fraud warnings, terrorism disclosure, rebating and case law on fraud and sublimits. 3. **Market.** A test of every feature against loss data and U.S. market practice, which led me to drop several features that looked good but protected little.

Regulatory status as of September 27, 2026:

Item	Status	Effect on the policy
CIRCI final rule (federal incident and ransom-payment reporting)	Not confirmed as published	The policy already lets insureds make any legally required report without consent
California SB 690 (ends private suits under California's pen-register and trap-and-trace law over website and app tracking)	Passed the Legislature August 28, 2026; awaiting the Governor's decision (deadline September 30, 2026); would take effect January 1, 2027	Wiretapping and other California Invasion of Privacy Act claims would remain, so Coverage Q stays
California SB 446	In effect January 1, 2026: 30-day consumer breach notice	Breach response is built around 30-day deadlines
Colorado AI law (SB 26-189)	Signed May 2026; effective January 1, 2027	AI regulatory defense deferred (part 9)
ISO generative-AI exclusions for general liability	Optional endorsements since January 2026	Affirmative AI cover is now common in cyber (Beazley, CFC). Harborline's distinctive element is its AI-agent definition

Sources

Policy forms and products - At-Bay, Cyber Insurance Policy form AB-CYB-001.2 (08/2023): <https://www.at-bay.com/wp-content/uploads/2023/06/Cyber-Insurance-Policy-Form.pdf> - At-Bay issued cyber policy, 2025–26 (ASTRO America): https://astroa.org/wp-content/uploads/2025/04/Corrected_Stamped_Policychecked4_9_25_ki.pdf - Coalition Cyber Policy, issued policy 2025–26: https://mwvhomelessalliance.org/wp-content/uploads/2026/02/8._Cyber-Policy.pdf - Coalition, Active Cyber Policy FAQ (surplus lines from April 15, 2025): <https://help.coalitioninc.com/hc/en-us/articles/33998071846811-Active-Cyber-Policy-FAQ> - Coalition, Enhanced Business Recovery (2026): <https://www.coalitioninc.com/blog/cyber-insurance/introducing-enhanced-business-recovery> - Coalition, Deepfake Response Endorsement (December 2025): <https://www.coalitioninc.com/announcements/coalition-adds-deepfake-response-endorsement> - Beazley, War and Cyber War Exclusion (E15626): <https://lmalloyds.com/wp-content/uploads/2025/09/Beazley-War-and-Cyber-War-Exclusion-1.pdf> - Beazley, BBR 5.0 Enhancements and Clarifications: <https://www.beazley.com/globalassets/full-spectrum-cyber/bbr-5.0-enhancements-and-clarifications.pdf> - HSB Cyber Suite Coverage Form CSC 02-2025: <https://heartlandmutualinsurance.com/wp-content/uploads/2024/12/Cyber-Suite-Coverage-Form-CSC-02-2025.pdf> - Cowbell Prime 100 overview: <https://cowbell.insure/wp-content/uploads/pdfs/CB-Prime100-Overview.pdf> - Corgi, Cyber Liability: <https://www.corgi.insure/cyber-liability> - Corgi Insurance Company launch (August 26, 2026): <https://www.prnewswire.com/news-releases/corgi-insurance-launches-admitted-insurance-carrier-302860246.html> - AIG and Parametrix cloud-outage product (August 13, 2026): <https://www.theinsurer.com/cyber-risk/news/aig-launches-parametric-cloud-outage-solution-backed-by-parametrixs-monitoring-2026-08-13/> - Brit C360 (March 2026): <https://www.britinsurance.com/news/brit-launches-new-cyber-product-for-smes>

Claims and market data - At-Bay, The 2026 InsurSec Report (April 2026), full PDF: source of the \$180K, \$208K, \$422K, \$508K and 14% figures - Coalition, 2026 Cyber Claims Report: <https://www.coalitioninc.com/claims-report/2026> - Coalition, Understanding Why Privacy Claims Doubled in H1 2026 (July 2026): <https://www.coalitioninc.com/blog/cyber-insurance/understanding-why-privacy-claims-doubled-in-h1-2026> - Duane Morris, Data Breach Class Action Review 2026: <https://blogs.duanemorris.com/classactiondefense/2026/02/03/hot-off-the-presses-the-duane-morris-data-breach-class-action-review-2026-and-the-duane-morris-privacy-class-action-review-2026/> - Marsh, U.S. Insurance Market Rates Q2 2026: <https://www.marsh.com/en/services/international-placement-services/insights/us-insurance-rates.html> - Aon, CrowdStrike event briefing (July 2024): <https://www.aon.com/en/insights/alerts/crowdstrike-and-windows-event-briefing-implications-and-initial-findings-for-cyber-reinsurers> - Accounting Today, The Wolters Kluwer CCH outage (2019): <https://www.accountingtoday.com/news/the-wolters-kluwer-cch-outage-what-happened> - HR Dive, Kronos outage (December 2021): <https://www.hrdive.com/news/all-hands-on-deck-for-hr-teams-as-kronos-outage-drags-on/611811/>

Law and regulation - NIST Cybersecurity Framework 2.0 (2024): <https://www.nist.gov/cyberframework> - CIS Critical Security Controls v8.1 (2024): <https://www.cisecurity.org/controls/v8-1> - U.S. Treasury OFAC, ransomware advisory (September 21, 2021): <https://ofac.treasury.gov/media/912981/download> - FTC Safeguards Rule, 16 CFR Part 314: <https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314> - UK National Cyber Security Centre, Guidance for organisations considering payment in ransomware incidents (May 2024): <https://www.ncsc.gov.uk/guidance/organisations-considering-payment-in-ransomware-incidents> - UK Insurance Act 2015, section 11: <https://www.legislation.gov.uk/ukpga/2015/4/section/11> - Lloyd's Market Bulletin Y5381, state-backed cyber-attack exclusions (August 16, 2022) - U.S. Treasury, guidance on stand-alone cyber policies under the

Terrorism Risk Insurance Program (December 27, 2016) - Colorado SB25-058, insurance rebate reform:
<https://leg.colorado.gov/bills/sb25-058> - Colorado statutes: C.R.S. 10-4-109.7 (cancellation notice), 10-1-128 (fraud warning), 5-12-102 (interest), 10-3-1115/1116 (unreasonable delay or denial)

Cases - *Merck & Co. v. ACE American Insurance Co.*, 475 N.J. Super. 420 (App. Div. 2023) - *Travelers Property Casualty Co. v. International Control Services*, No. 22-cv-2145 (C.D. Ill. 2022) - *CiCi Enterprises v. HSB Specialty Insurance Co.* (N.D. Tex. February 23, 2026) - *Taylor & Lieberman v. Federal Insurance Co.* (9th Cir. 2017) - *RealPage, Inc. v. National Union Fire Insurance Co.* (5th Cir. 2021) - *Mississippi Silicon Holdings v. AXIS Insurance Co.* (5th Cir. 2021) - *Apache Corp. v. Great American Insurance Co.*, 662 F. App'x 252 (5th Cir. 2016) - *Craft v. Philadelphia Indemnity Insurance Co.*, 2015 CO 11